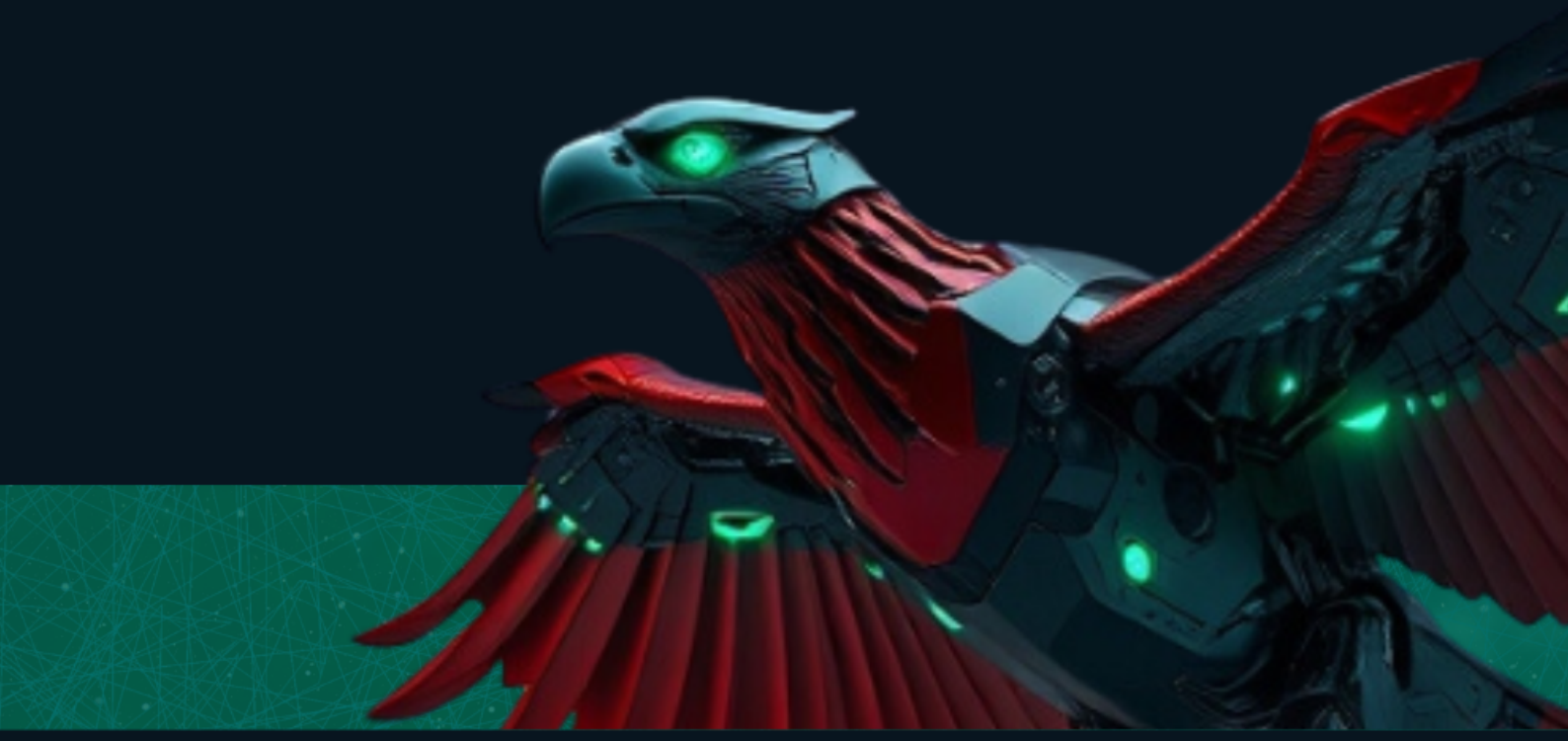
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Threat Advisory | CVE-2026-64849
Sub Title	Server-Side Request Forgery (SSRF) vulnerability in MLflow
Status	Closed
Type	Advisory
Severity	High
Source	TheHackerNews.com
Created At	Aug 24, 2026, 08:36 PM

Threat Advisory | CVE-2026-64849

Server-Side Request Forgery (SSRF) vulnerability in MLflow

Type: ADVISORY • Source: TheHackerNews.com • Created At: Aug 24, 2026, 08:36 PM

Analysis Summary

CVE-2026-64849 is an unauthenticated Server-Side Request Forgery (SSRF) vulnerability affecting MLflow versions prior to 3.15.0. MLflow is an open-source platform designed to manage the end-to-end machine learning (ML) lifecycle. It helps data scientists and machine learning engineers track experiments, package code into reproducible runs, and share or deploy models across different platforms. Cybersecurity researchers at security firms watchTowr and VulnCheck identified active scanning and exploitation efforts targeting this flaw, with watchTowr reporting malicious threat actors scanning for exposed instances within hours of its official CVE assignment on August 17, 2026. The U.S. Cybersecurity and Infrastructure Security Agency (CISA) added it to its Known Exploited Vulnerabilities catalog shortly after, requiring federal agencies to apply immediate patches.

The flaw stems from how MLflow handles web redirects within its model-registry webhooks, allowing remote attackers to bypass previous security fixes and proxy malicious HTTP requests through the tracking server (mlflow server). Unauthenticated attackers and automated botnets exploit this flaw by targeting publicly exposed MLflow instances to interact directly with internal network services and cloud metadata endpoints. By querying well-known internal IP addresses, threat actors actively use this exploit to extract sensitive environment data, cloud service credentials, and security secrets.

If exploited within your environment, this vulnerability poses a severe threat to cloud infrastructure security and access controls. Unauthenticated access to cloud metadata endpoints can lead to full credential exfiltration, granting attackers legitimate administrative access to broader cloud environments, storage buckets, and databases. The primary impact includes cross-service lateral movement, potential operational disruption,

and unauthorized data access, making immediate patching to MLflow 3.15.0 or later and reviewing server audit logs critical to preventing compromise.

Affected Product

- MLflow versions before 3.15.0

Impact

- Credential compromise
- Lateral movement
- Sensitive data exfiltration
- Cloud account compromise

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-64849	MLflow is an open source AI engineering platform for agents, large language models, and machine learning models. Prior to 3.15.0, the unauthenticated POST /api/2.0/mlflow/webhooks/{id}/test endpoint calls _validate_webhook_url() in mlflow/utils/validation.py only for the original URL while mlflow/webhooks/delivery.py follows redirects and re-resolves the hostname without pinning the validated address, allowing attackers to reach internal or cloud metadata services and receive response_status and response_body. This issue is fixed in version 3.15.0.	8/16/2026	9.3

Remediation

- Remove public exposure and restrict MLflow access through private networking, VPN, reverse proxy, or identity aware authentication.
- Block access to “POST /api/2.0/mlflow/webhooks/{id}/test” and webhook management routes until patching is complete.
- Enforce egress restrictions that deny MLflow connections to loopback, link-local, cloud metadata (169.254.169.254), RFC1918, Kubernetes service, and other internal network ranges.
- Review logs for webhook test activity, rotate potentially exposed cloud credentials, workload identities, API keys, and secrets if exploitation is suspected.
- Upgrade immediately to a fixed release of MLflow deployments 3.15.0 or later, which contains the fix for the Server-Side Request Forgery (SSRF) vulnerability CVE-2026-64849.